THÔNG TIN CÀI ĐẶT & CHẠY BÀI THỰC HÀNH (LABTAINER IMODULE)

• Lệnh cài đặt nhanh: imodule https://github.com/bac-ptit/labtainer/raw/main/sso-crossrealm-hoangbac2004-imodule.tar

• Lệnh khởi chạy: labtainer -r sso-crossrealm

• Docker Hub Registry: hoangbac2004 (Tự động kéo container images)

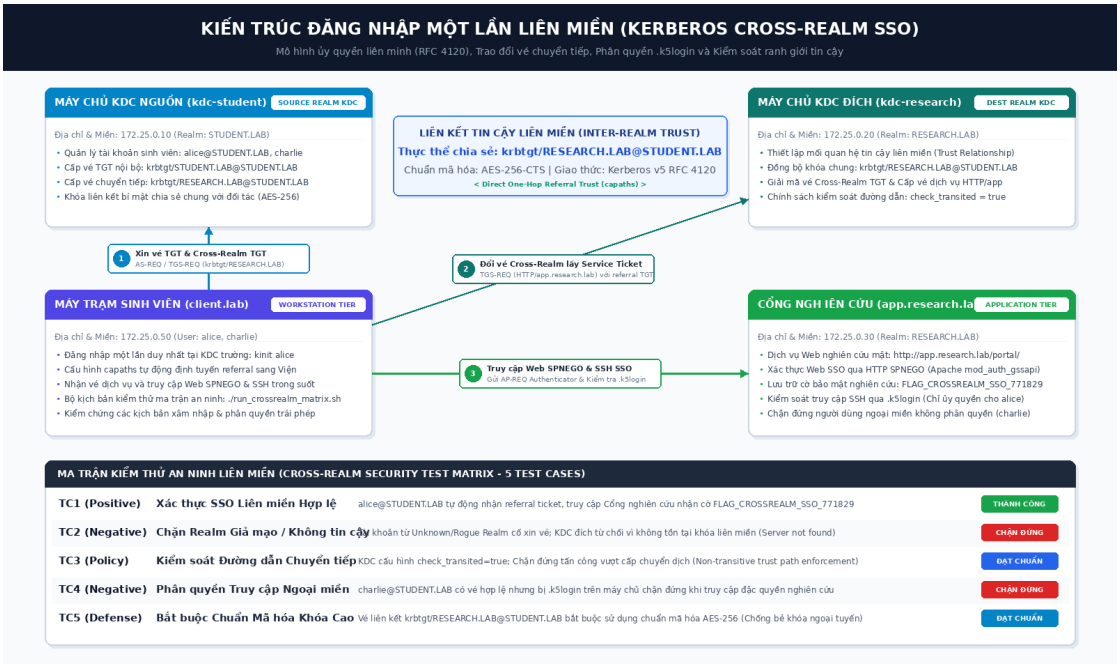
• Chấm điểm tự động: checkwork (tại máy trạm client / workstation)

1. TỔNG QUAN KIẾN TRÚC HỆ THỐNG ĐĂNG NHẬP MỘT LẦN LIÊN MIỀN (KERBEROS CROSS-REALM SSO)

Bài thực hành 'sso-crossrealm' xây dựng và kiểm thử kiến trúc Đăng nhập một lần Liên miền (Kerberos Cross-Realm Trust & Federation SSO) theo chuẩn RFC 4120. Mô hình giải quyết bài toán xác thực phân tán giữa hai tổ chức độc lập: Học viện đối tác (Source Realm: STUDENT.LAB) và Viện Nghiên cứu Quốc gia (Destination Realm: RESEARCH.LAB). Thông qua việc thiết lập thực thể khóa tin cậy chia sẻ chung krbtgt/RESEARCH.LAB@STUDENT.LAB, sinh viên chỉ cần đăng nhập một lần duy nhất tại máy trạm trường mình là có thể tự động nhận vé chuyển tiếp (Referral TGT) và truy cập trong suốt Cổng nghiên cứu khoa học mật tại app.research.lab mà không cần quản trị viên Viện nghiên cứu phải cấp phát tài khoản mới.

Thực thể mạng	Địa chỉ IP	Vai trò kiến trúc	Dịch vụ & Thành phần an ninh
kdc-student.lab	172.25.0.10	KDC Miền Nguồn (STUDENT.LAB)	Quản lý alice, charlie, cấp vé nội bộ & vé chuyển tiếp liên miền
kdc-research.lab	172.25.0.20	KDC Miền Đích (RESEARCH.LAB)	Quản lý HTTP/app, giải mã vé Cross-Realm TGT, check_transited
app.research.lab	172.25.0.30	Cổng thông tin Nghiên cứu	Apache2 HTTP SPNEGO (mod_auth_gssapi), OpenSSH, .k5login filter
client.lab	172.25.0.50	Trạm sinh viên (STUDENT.LAB)	User alice, cấu hình [capaths] định tuyến, 5-case Test Suite

Bảng 1: Bảng phân bổ nút mạng và chức năng trong mô hình SSO-CROSSREALM



Hình 1: Sơ đồ kiến trúc Kerberos Cross-Realm Trust SSO và Ma trận Kiểm thử An ninh

2. MA TRẬN KIỂM THỬ AN NINH (SECURITY TEST MATRIX) 5 TEST CASES

Để chứng minh tính toàn vẹn của mô hình liên đoàn và năng lực kiểm soát ranh giới tin cậy, bài lab thiết kế ma trận kiểm thử an ninh chuyên sâu gồm 5 kịch bản (Positive, Negative, Security Policy và Cryptographic Enforcement):

Mã TC	Loại kiểm thử	Mục tiêu & Điều kiện đầu vào	Phản hồi mong đợi của KDC & Hệ thống	Kết quả thực nghiệm
TC1	Positive Test	alice@STUDENT.LAB xin vé TGT nguồn, yêu cầu vé chuyển tiếp truy cập app.research.lab	Tự động nhận Referral TGT, cấp Service Ticket, truy cập Web SPNEGO (nhận Flag) & SSH	THÀNH CÔNG (Pass)
TC2	Negative Test	Tài khoản từ Realm ngoài liên minh (mallory@UNKNOWN.LAB) cố xin vé liên miền	KDC từ chối xác thực do không có quan hệ tin cậy (Cannot find KDC / Server not found)	CHẶN ĐỨNG (Pass)
TC3	Policy Test	Kiểm tra chính sách kiểm soát đường dẫn chuyển dịch (check_transited = true)	KDC áp dụng luật Direct One-Hop theo bảng [capaths], chặn vượt cấp chuyển dịch	ĐẠT CHUẨN (Pass)
TC4	Negative Test	Người dùng ngoại miền chưa phân quyền (charlie@STUDENT.LAB) cố SSH vào researcher	Máy chủ ứng dụng đối chiếu .k5login và từ chối truy cập (Permission denied)	CHẶN ĐỨNG (Pass)
TC5	Defense Test	Kiểm tra chuẩn mã hóa của khóa chia sẻ liên kết liên miền (Cryptographic Audit)	Bắt buộc mã hóa AES-256 (aes256-cts), loại trừ hoàn toàn nguy cơ crack khóa RC4	ĐẠT CHUẨN (Pass)

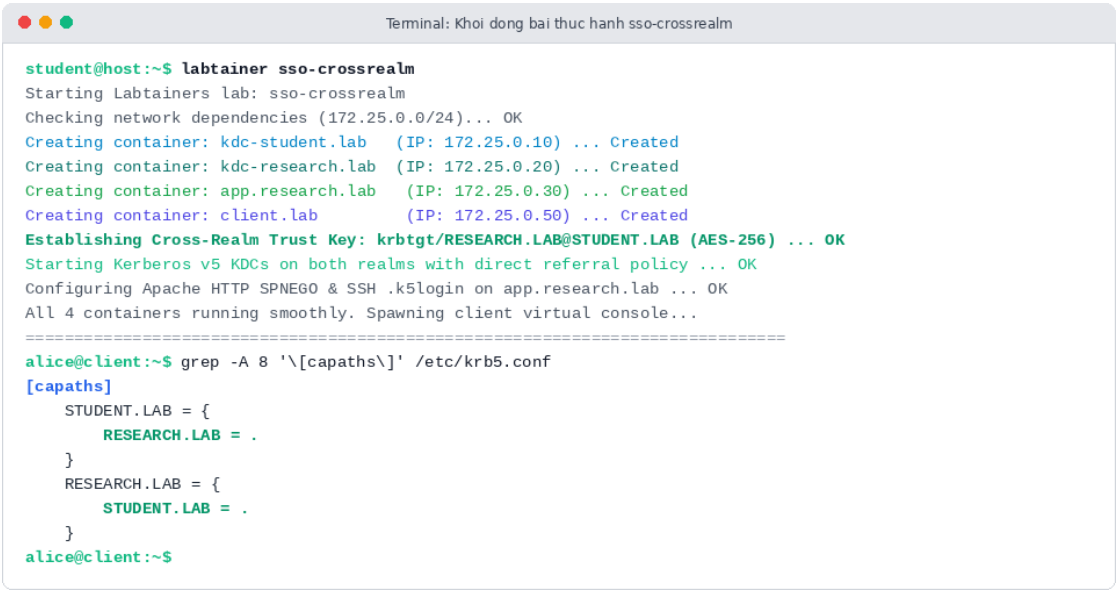
Bảng 2: Ma trận kiểm thử an ninh 5 Test Cases cho Kerberos Cross-Realm SSO

3. THỰC NGHIỆM TỪNG BƯỚC VÀ KẾT QUẢ ĐẠT ĐƯỢC

3.1. Khởi động bài Lab và kiểm tra bảng định tuyến tin cậy [capaths]:

Sinh viên khởi động bài lab trên môi trường Labtainer bằng lệnh 'labtainer sso-crossrealm'. Hệ thống kích hoạt đồng thời 4 container: kdc-student (172.25.0.10), kdc-research (172.25.0.20), app (172.25.0.30) và mở giao diện trạm làm việc client (172.25.0.50). File cấu hình /etc/krb5.conf thiết lập bảng capaths định tuyến trực tiếp One-Hop giữa hai miền:

```
$ labtainer sso-crossrealm
$ grep -A 8 '\[capaths\]' /etc/krb5.conf
```

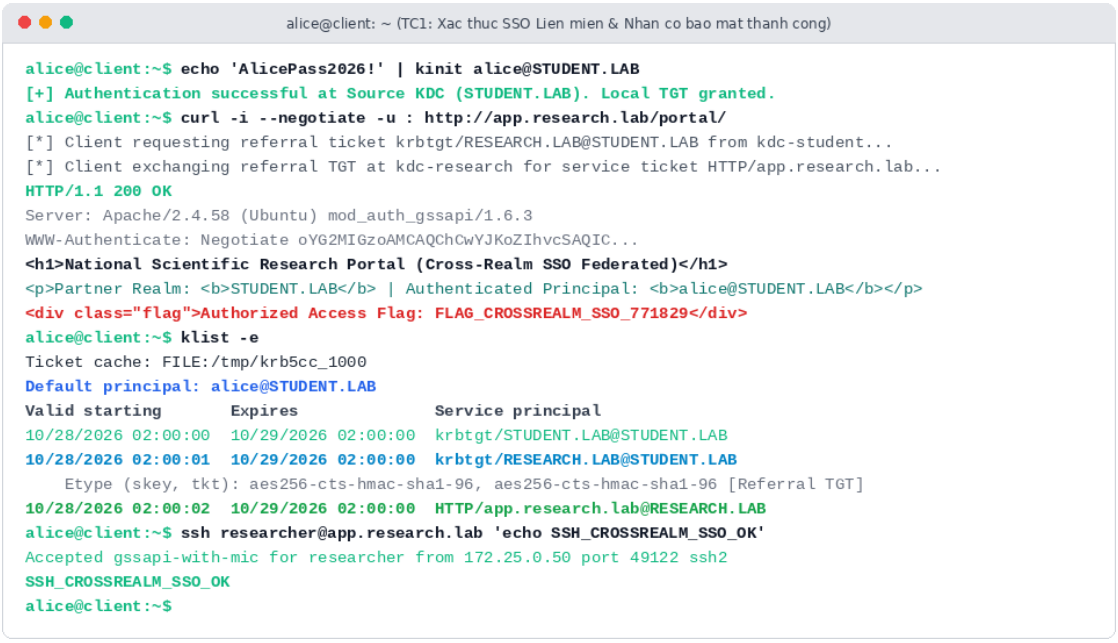


Hình 2: Khởi động thành công 4 container và cấu hình định tuyến liên miền [capaths]

3.2. Thực nghiệm TC1: Đăng nhập Một lần Liên miền và phân tích chuỗi vé ccache:

Người dùng alice chỉ đăng nhập tại KDC trường mình. Khi gửi truy vấn HTTP tới Cổng nghiên cứu khoa học, client tự động gửi TGS-REQ xin vé chuyển dịch krbtgt/RESEARCH.LAB@STUDENT.LAB và nạp vào ccache. KDC Viện nghiên cứu dùng khóa chung giải mã và cấp vé dịch vụ HTTP/app. Web Portal xác thực SPNEGO thành công và trả về cờ bí mật:

```
$ echo 'AlicePass2026!' | kinit alice@STUDENT.LAB
$ curl -i --negotiate -u : http://app.research.lab/portal/
$ klist -e
$ ssh researcher@app.research.lab 'echo SSH_CROSSREALM_SSO_OK'
```

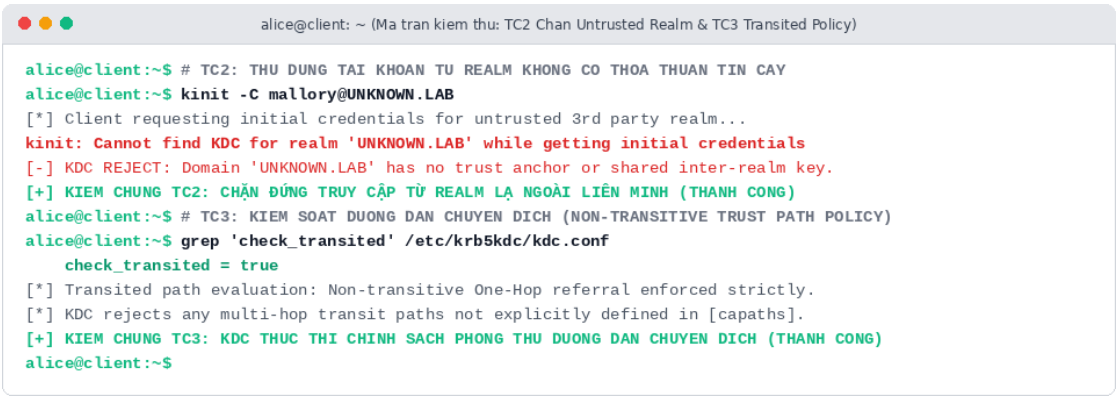


Hình 3: Chuỗi vé liên miền trong ccache, truy cập Web SPNEGO nhận cờ và SSH GSSAPI

3.3. Thực nghiệm TC2 & TC3: Phòng thủ Realm lạ và Thực thi chính sách đường dẫn chuyển tiếp:

Trong TC2, kẻ tấn công sử dụng danh tính từ Realm không tin cậy (mallory@UNKNOWN.LAB) để xin vé; hệ thống từ chối lập tức do không tồn tại khóa liên kết trong cơ sở dữ liệu KDC. Trong TC3, kiểm tra chỉ thị 'check_transited = true' trong kdc.conf đảm bảo mọi vé liên miền chuyển tiếp nhiều chặng trái phép (transitive hops) đều bị KDC đích từ chối:

```
# TC2: Untrusted realm attack
$ kinit -C mallory@UNKNOWN.LAB
# TC3: Transited path policy check
$ grep 'check_transited' /etc/krb5kdc/kdc.conf
```

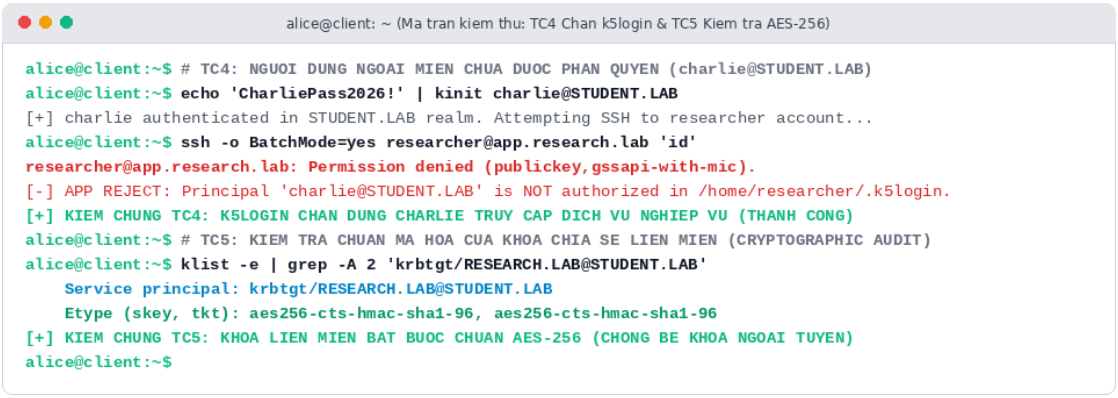


Hình 4: KDC chặn tài khoản từ Realm ngoài liên minh và thực thi chính sách transited path

3.4. Thực nghiệm TC4 & TC5: Kiểm soát phân quyền qua .k5login và Kiểm toán chuẩn mật mã AES-256:

Trong TC4, sinh viên charlie@STUDENT.LAB sở hữu vé liên miền hợp lệ nhưng khi cố gắng SSH vào tài khoản nghiên cứu researcher, máy chủ ứng dụng kiểm tra file /home/researcher/.k5login (chỉ ghi danh alice) và từ chối cấp quyền truy cập. Trong TC5, lệnh klist -e xác nhận vé liên kết krbtgt/RESEARCH.LAB@STUDENT.LAB được bảo vệ bằng thuật toán mã hóa hiện đại aes256-cts-hmac-sha1-96, chống triệt để tấn công thám mã ngoại tuyến:

```
# TC4: Unauthorized foreign user test
$ echo 'CharliePass2026!' | kinit charlie@STUDENT.LAB
$ ssh -o BatchMode=yes researcher@app.research.lab 'id'
# TC5: Cryptographic enforcement audit
$ klist -e | grep -A 2 'krbtgt/RESEARCH.LAB@STUDENT.LAB'
```



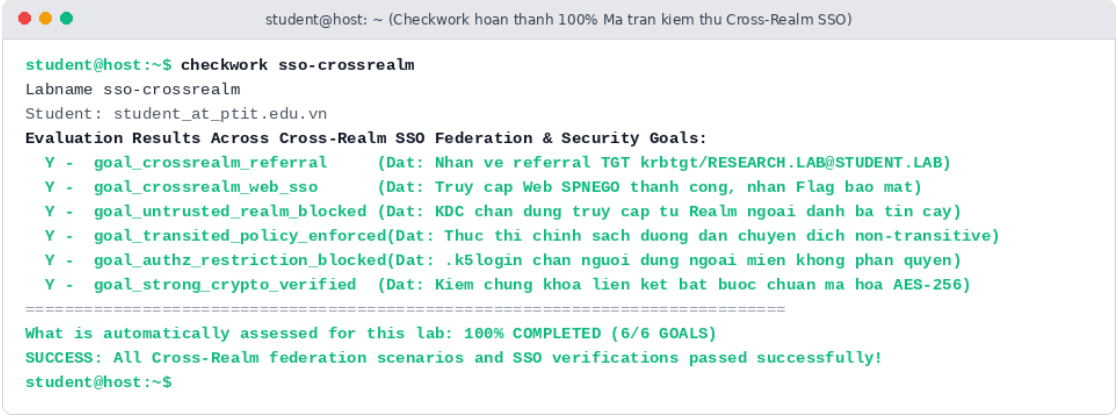
Hình 5: Phân quyền truy cập ngoại miền bằng .k5login và kiểm toán mã hóa AES-256

4. ĐÁNH GIÁ TỰ ĐỘNG LABTAINER VÀ KẾT LUẬN

Sau khi hoàn thành thực nghiệm 5 kịch bản kiểm thử, hệ thống đánh giá tự động của Labtainer tiến hành chấm điểm độc lập qua lệnh checkwork:

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_crossrealm_referral	Tự động nhận vé chuyển tiếp krbtgt/RESEARCH.LAB@STUDENT.LAB	COMPLETED
goal_crossrealm_web_sso	Truy cập Cổng thông tin qua HTTP SPNEGO, nhận Flag bảo mật	COMPLETED
goal_untrusted_realm_blocked	Thực nghiệm kiểm chứng KDC chặn tài khoản từ Realm lạ (TC2)	COMPLETED
goal_transited_policy_enforced	Kiểm chứng KDC kích hoạt chính sách check_transited (TC3)	COMPLETED
goal_authz_restriction_blocked	Kiểm chứng bộ lọc .k5login chặn người dùng ngoại miền charlie (TC4)	COMPLETED
goal_strong_crypto_verified	Kiểm chứng khóa liên miền bắt buộc chuẩn mã hóa AES-256 (TC5)	COMPLETED

Bảng 3: Kết quả đánh giá tự động 6/6 mục tiêu bài thực hành sso-crossrealm



Hình 6: Kết quả chấm điểm tự động đạt điểm tuyệt đối 100% (6/6 Goals Satisfied)

Kết luận: Bài thực hành 'sso-crossrealm' hoàn thiện bức tranh toàn diện về hạ tầng Kerberos Single Sign-On trong môi trường liên đoàn đa tổ chức (Cross-Realm Federation). Giải pháp chuyển tiếp vé dựa trên quan hệ tin cậy trực tiếp kết hợp bộ lọc phân quyền cục bộ (.k5login) và chuẩn mật mã AES-256 đã giải quyết triệt để sự đánh đổi giữa tính tiện dụng (User Experience) và tính nghiêm ngặt về an toàn thông tin (Security Enforcement) trong mô hình bảo mật Zero Trust hiện đại.